VISUALPES

Spécification d'Architecture — Gestion des Droits Multi-Tenant

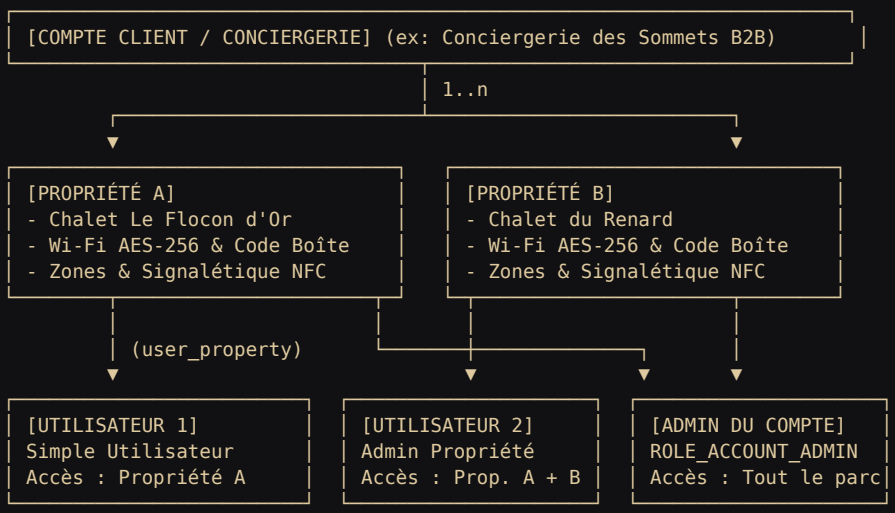
Réf : **DOC-PERM-2026-v2**
Date : **27 Octobre 2026**
Statut : **Validé & En Production**
Portée : **ERP VisuAlpes & Portail Client**

Stratégie Directrice : Compte > Propriété(s) > Utilisateur(s)

L'écosystème phygital VisuAlpes (plaques bois massif gravées, puces NFC, livrets d'accueil et coffres-forts Wi-Fi AES-256) repose sur un partitionnement hiérarchique strict garantissant sécurité, autonomie et non-divulgation des données :

1. COMPTE CLIENT	2. HÉBERGEMENT(S)	3. COLLABORATEUR(S)
Account (B2B / B2C)	**Property (1..n)**	**User (1..n)**
Entité racine propriétaire (Conciergerie, Syndic ou Particulier). Isole tout le portefeuille.	Rattaché à un seul compte. Fiche enrichie, Wi-Fi chiffré, code boîte à clés & zones NFC.	Rattaché à une seule conciergerie, mais habilité sur un ou plusieurs hébergements du compte.

1. SCHÉMA D'ISOLATION ET RELATIONS



2. MATRICE DES RÔLES & NIVEAUX D'HABILITATION

RÔLE & IDENTIFIANT	PÉRIMÈTRE D'ACCÈS	CAPACITÉS OPÉRATIONNELLES	GESTION D'ÉQUIPE
`ROLE_ACCOUNT_ADMIN` **Admin du Compte**	**Totalité du Compte** Accès automatique à tous les chalets actuels et futurs.	Gestion complète des chalets, Wi-Fi chiffré, boîtes à clés, commandes atelier, livrets et SAV.	**Pouvoir complet :** Crée, modifie et supprime les membres et assigne les droits par chalet.
`ROLE_PROPERTY_ADMIN` **Admin Propriété**	**Propriétés Assignées** Restreint aux chalets cochés via `user_property`.	Gestion autonome des chalets assignés : Wi-Fi, mise à jour code boîte à clés, zones et signalétique.	**Aucun droit :** Ne peut pas gérer les autres collaborateurs.
`ROLE_USER` **Simple Utilisateur**	**Propriétés Assignées** Restreint aux chalets cochés.	Consultation opérationnelle (accueil voyageur, ménage, codes d'accès et zones NFC).	**Aucun droit :** Mode consultation de l'équipe sans bouton d'action.
`ROLE_ADMIN` **Admin Global VisuAlpes**	**Plateforme Complète** Multi-comptes, atelier et configuration.	Super-administrateur : accès à toutes les conciergeries, hébergements, fabrication et déclencheur SAV.	Administration de l'ensemble des utilisateurs système.
`ROLE_ATELIER` **Artisan Atelier**	**Atelier & Fabrication**	Fabrication des plaques bois gravées, encodage des puces NFC NTAG213 et gestion des stocks.	Aucune gestion d'utilisateurs clients.

3. IMPLÉMENTATION BACKEND & SÉCURITÉ SYMFONY

3.1. Hiérarchie des Rôles (`api/config/packages/security.yaml`)

La hiérarchie native de Symfony assure l'héritage descendant des permissions :

```
security: role_hierarchy: ROLE_ADMIN: [ROLE_ACCOUNT_ADMIN, ROLE_ATELIER] ROLE_ACCOUNT_ADMIN: [ROLE_PROPERTY_ADMIN] ROLE_PROPERTY_ADMIN: [ROLE_USER]
```

3.2. Cloisonnement Automatique Doctrine (`CurrentAccountExtension.php`)

Chaque requête API Platform (collection ou élément unitaire) est filtrée au niveau SQL/DQL :

- **Staff VisuAlpes (`ROLE_ADMIN`)** : Accès sans restriction à l'ensemble des données.
- **Admin du Compte (`ROLE_ACCOUNT_ADMIN`)** : Clause `alias.account = :current_account` pour afficher toutes les propriétés du portefeuille.
- **Admin Propriété & Simple Utilisateur** : Clause combinée étanche :
  `alias.account = :current_account AND alias IN (:assigned_properties)`
  Si l'utilisateur n'a aucune propriété assignée, la clause de verrouillage `1 = 0` s'applique immédiatement (zéro fuite de données).

3.3. Contrôleur Équipe & Anti-Élévation de Privilèges (`ClientPortalController.php`)

- `POST /api/client/team` : Réservé aux `ROLE_ACCOUNT_ADMIN`. Valide l'unicité de l'email, hache le mot de passe, vérifie l'appartenance des propriétés au compte client et dispatche l'invitation.
- `PATCH /api/client/team/{id}` : Mise à jour du rôle (Compte, Propriété, Simple Utilisateur), mot de passe et réaffectation des chalets.
- `DELETE /api/client/team/{id}` : Révocation du compte collaborateur avec blocage de l'auto-suppression.
- **Anti-escalade (`UserPasswordHasherProcessor`)** : Un admin de compte ne peut pas s'auto-attribuer ni octroyer de rôle staff (`ROLE_ADMIN` ou `ROLE_ATELIER`). Le compte de l'utilisateur créé est obligatoirement verrouillé sur celui du créateur.

3.4. Assistance SAV & Régénération de Mot de Passe à Distance (`AdminUserController.php`)

Accessible par l'Atelier VisuAlpes et par l'Administrateur du Compte :

- **Pass Temporaire Immédiat** : Génère un mot de passe temporaire robuste (ex : `Alpes-2026-Xk8p`), l'applique instantanément au compte et l'affiche à l'écran pour dictée téléphonique ou copie presse-papier en 1 clic.
- **Lien Sécurisé 30 min** : Émet un jeton cryptographique horodaté et envoie un code à 6 chiffres par email officiel.

4. INTERFACES UTILISATEUR DÉPLOYÉES

ERP Centralisé VisuAlpes (`/va-admin`)

- **Comptes Clients** : Liste dépliable sans statistiques superflues, affichage B2B/B2C, coordonnées de facturation, notes atelier et compteurs croisés (Propriétés, Commandes, Collaborateurs).
- **Propriétés** : Liste dépliable avec en-tête synthétique rotatif (typologie, station, Wi-Fi, puces NFC) et détails complets (boîte à clés avec copie, coffre-fort Wi-Fi démasquable, zones et signalétique).
- **Gestion des Utilisateurs** : Tableau de bord avec filtre multi-rôles, attribution dynamique des logements selon le compte sélectionné, et déclencheur SAV à distance.

Portail Client Conciergerie (`/`)

- **Onglet Équipe & Collaborateurs** :
  - *Admin du Compte* : Bouton `+ Inviter un collaborateur`, sélection du rôle (Admin Compte, Admin Propriété, Simple Utilisateur) et cases à cocher des chalets autorisés.
  - *Autres rôles* : Mode consultation protégé avec mention des chalets attribués.
- **Vue Propriétés** : Les gestionnaires et simples utilisateurs ne visualisent que les hébergements auxquels l'administrateur leur a ouvert l'accès.